

Lab 02: Vulnerability Assessment

Cybersecurity F26

February 11th, 2026

Lab Exercises (After Nessus and GVM Installation)

Nessus and GVM Installation and Set-up

For the installation and set-up of Nessus and GVM, I'll not go into the detailed step-by-step process. Instead, I'll summarize the important steps according to my set-up. For more information, use the documentation links provided.

Also, while registering your Nessus, select the Essential Plus for students and educators¹ and sign up using your student email. This provides you with one-year unlimited scanning of up to 20 IPs with real-time plugin updates.

As for GVM, it is open source and free. So, there's no need to sign up. However, it is worth noting that GVM is sensitive against database updates. In case of database issues not easily fixed by troubleshooting, it might be easiest to apt purge and reinstall.

Installing the Setting Up Nessus

1. Visit the [Nessus vulnerability scanner webpage](#) in your Kali machine.
2. Complete the registration form to receive your activation code. I'll recommend you register for the [free access for students and educators](#) which provides you with 1 year free access.
3. Proceed to the Downloads page and download the latest version for Debian kali.
4. After the download, open a terminal and navigate to the directory containing the downloaded file, and install Nessus via:
`sudo dpkg -i Nessus-11.1.2-debian10_amd64.deb`
5. After the installation is complete, start the Nessus service via terminal:
`sudo systemctl start nessusd`
6. Access it via your web browser at <https://localhost:8834/>

¹ <https://www.tenable.com/tenable-nessus-for-education>

7. Select 'Register for Nessus Essentials' in the welcome page and sign in using your username and password.
8. Wait for plugin download and database initialization to complete. Then you are ready to start using Nessus Essentials.

More Info: <https://docs.tenable.com/nessus/Content/InstallNessusLinux.htm>

Installing and Setting Up GVM

1. Use the terminal to install GVM via: `sudo apt install openvas -y`
2. Setup the first time, use: `sudo gvm-setup`
3. Check setup is complete: `sudo gvm-check-setup`
4. Start GVM webservice using: `sudo gvm-start`
5. Access via the web browser at <https://localhost:9392/>
6. Sign in using the default password it provided you with after the installation. But I'll recommend you change the password.
7. Change admin password using:
`sudo runuser -u _gvm -- gvmc --user=admin --new-password=XYZ`
8. Wait for feed to finish syncing. Then you're good to go.

More info: <https://greenbone.github.io/docs/latest/22.4/kali/index.html>

GVM Troubleshooting:

<https://greenbone.github.io/docs/latest/22.4/kali/troubleshooting.html>

Lab Exercises

1. Introduction

In this Lab, you will perform a vulnerability assessment against the intentionally vulnerable target systems deployed in the previous lab. The goal is to identify, classify, and understand security weaknesses before attempting exploitation. You will perform the core steps of a vulnerability assessment. These steps reflect a typical professional pen testing workflow:

- Information Gathering: Collect contextual information about a target (e.g., organization details, IP address ranges, etc).
- IP Address and Service Scanning: Identify active hosts and determine which services are running on specific IP addresses.

- Fingerprinting and Enumeration: Gather detailed information about systems and services, such as web servers, operating systems, user accounts, and application versions.
- Reporting: Summarize and document the gathered information.

Submission and Exam Relevance

This is the first of six lab exercises that is to be submitted via itslearning. The submissions are not mandatory. However, they serve an important purpose, which includes reference material for revision and supporting material during the final written exam. Also, you may be expected to reference, explain, or reason about information produced in one or more submitted lab exercises. It is important to understand and reuse the content of your submissions during the exam, not just reproduce them.

Time and Resource Considerations

Some vulnerability scans can take a significant amount of time to complete. Progress indicators may not always reflect this accurately. Plan to run scans at a time when your machine can remain powered on and uninterrupted. Keep in mind that many security tools are designed for professional use and often prioritize functionality over usability.

Exercise 1: Gathering Information with whois

In this exercise, you will use the `whois` tool to gather publicly available information about domains and IP addresses. The goal is to understand what types of information can be obtained during the initial reconnaissance phase of a vulnerability assessment.

Tasks

1. Use `whois` to gather information about SDU by querying the domain: `sdu.dk`
2. Resolve the IP address of www.sdu.dk and perform a `whois` query on that IP address.
3. Based on the `whois` output, what information can you infer about SDU's network? Identify and record the IP address range(s) associated with SDU.
4. Consider whether there are other SDU-hosted network services that could be queried using `whois`.
5. Which services or hostnames might be relevant?
6. Why would an attacker or security analyst be interested in them?
7. Perform a `whois` query for `nextcloud.sdu.dk` (using the associated IP address).
8. Compare the results with the information obtained for www.sdu.dk
9. What similarities or differences do you observe?

10. What might explain these differences?

Note on usage: `whois` can be used on both domain names and IP addresses. Also, to gather information about specific hosts, you must perform `whois` queries on the IP addresses associated with those hosts.

Exercise 2: Scanning the Metasploitable VMs with Nmap

In this exercise, you will use Nmap to perform active scanning of the Metasploitable 2 (Linux) and Metasploitable 3 (Windows) virtual machines. The objective is to compare different scanning techniques and understand how scan types affect the amount, quality, and reliability of the information obtained.

Tasks

1. Baseline scan: Perform a TCP SYN scan against the Metasploitable 2 & 3 targets.
2. Full TCP Connection Scan: Perform a TCP Connect scan against the same targets.
3. Comprehensive Detection Scan: Perform a scan that enables OS detection, service and version detection, and default script scanning.
4. Comparison and Analysis: For each scan, record and compare detected open ports, identified services and versions, scan duration, and level of detail in the results.
5. Based on your observations, discuss the differences between SYN scans and Connect scans, the additional information gained from OS, version, and script detection, as well as advantages and disadvantages of each scan type, and situations in which one scan type would be preferred over the others.

Exercise 3: Scanning with Nessus

In this exercise, you will use Nessus to perform an automated vulnerability assessment of the Metasploitable VMs. The goal is to understand how professional vulnerability scanners operate and how their results compare to manual and semi-manual scanning techniques such as Nmap.

Tasks

1. Configure the Nessus scan targeting the Metasploitable VMs by ensuring the correct target IP addresses are specified (e.g., 172.30.1.21/24)², and a suitable scan template is selected (e.g., basic network or advanced scan). Use the basic network for now.

² The /24 suffix specifies the size of the network and indicates that the entire subnet is scanned, not just a single host. Alternatively, you may enter the individual IP addresses of your Metasploitable VMs instead of scanning the full subnet

2. Launch the scan and allow it to complete.
3. Review the scan result and identify detected vulnerabilities, reported severity levels, and affected services.
4. Compare Nessus findings with the information gathered in Exercise 2 (Nmap scan).
 - Which vulnerabilities were predictable based on Nmap results?
 - Which findings were not obvious from Nmap alone?
 - Are there services detected by one tool but not the other?
5. What are the strengths and limitations of automated vulnerability scanners?
6. When should automated scans be supplemented with manual analysis?

Exercise 4: Scanning with Greenbone Vulnerability Manager (GVM) / OpenVAS

In this exercise, you will use the GVM to assess vulnerabilities in the Metasploitable VMs. GVM is a widely used open-source vulnerability scanning framework and provides functionality similar to commercial tools like Nessus.

Tasks

1. Navigate to Scans → Tasks. Create a new scan and define the scan targets
 2. Configure the GVM scan targeting the Metasploitable VMs using the correct IPs.
 3. Save the target configuration and start the scan
 4. Review the scan result and identify detected vulnerabilities, reported severity levels, and affected services.
 5. Compare GVM findings with the information gathered in Exercise 2 (Nmap scan).
- Important:** If you encounter synchronization errors, navigate to Administration → Feed Status and wait until all feeds report as up to-date. Then restart scanning again.

Exercise 5: Authenticated Scan with Nessus

In this exercise, you will perform an authenticated vulnerability scan using Nessus against the Metasploitable VMs. Unlike unauthenticated scans, authenticated scans provide the scanner with valid credentials, allowing deeper inspection of the target system. The objective is to understand how authentication affects scan coverage, accuracy, and the types of vulnerabilities that can be detected.

Tasks

1. Identify valid credentials for the Metasploitable target systems.
2. Configure the scan using the same process as in Exercise 3 (Task 1).
3. Before launching the scan, configure the authentication settings for the target systems

e.g., SSH credentials for Metasploitable 2 (Linux)

4. Launch the authentication scan and allow it to complete.
5. Review the authenticated scan result and identify detected vulnerabilities, reported severity levels, and affected services.

Exercise 6: Comparing the Automated Scan Tools

In this exercise, you will perform comparisons between the automated scan tools (Nessus and GVM). The goal is to critically evaluate their capabilities, results, and usability based on the experience gained in the previous exercises (Exercise 3 & 4).

Tasks

1. Review the results of both Nessus scans and GVM scans
2. Compare the tools with respect to number of detected vulnerabilities, severity ratings, types of vulnerabilities, and overlapping/discrepancies.
3. Identify potential false positives and vulnerabilities detected by one tool but not the other.
4. Any findings that require manual verification?

Exercise 7: Comparing the Authenticated and Unauthenticated Scans in Nessus

This exercise compares the results of the authenticated scan with the unauthenticated Nessus scan performed earlier. The goal is to understand the different scans and tradeoffs.

Tasks

1. Compare the number and types of vulnerabilities detected.
2. Compare the changes in severity levels
3. Any newly identified (local or configuration-related) vulnerabilities?

Exercise 8: Collecting Assessment Information

In this exercise, you will document selected vulnerabilities in the Metasploitable 2 & 3 target machine. The focus is on understanding, researching, and explaining vulnerabilities, rather than exploiting them. You will use the results from previous exercises to support your assessment.

Tasks

1. From the identified vulnerabilities in previous exercises, select 4 vulnerable services running on the Metasploitable 2 & 3 target machines each.

2. For each selected service, document the following:
 - Service identification, e.g., service name, port number, service/software version (e.g., FTP, port 21, version x.x.x)
 - Describe at least one vulnerability affecting the service.
 - Describe what an attacker could potentially achieve if vulnerability is exploited.
 - Assess the severity of vulnerability and justify your assessment based on impact.

Important: You do not need to explain how to exploit the vulnerability or provide technical exploit details. The detailed exploitation mechanics are outside the scope of this exercise and will be addressed in the next class. Instead, focus on severity and impact on real-world systems. Provide the relevant CVE identifiers if available or cite the source.

Exercise 9: Completing the Assessment

Now, you will create an assessment report based on the work completed in the previous exercises. The objective is to demonstrate your ability to interpret, prioritize, and communicate security findings. The report should cover an overall evaluation of security posture of Metasploitable 2 & 3.

Tasks

1. The report should provide high-level overview of the security conditions of both VMs, including assessment of how exposed/vulnerable each system is, comparison of overall risk level between the systems, and explanation of in attach surface and severity.
2. Based on the 4 vulnerably services selected in Exercise 7, the report should discuss relative severity of each vulnerability, and which should be prioritized first.
3. Support your analysis using results from the tools covered in previous exercises.

Important: Do not simply copy the severity ratings provided by automated tools. Instead, review the associated CVE descriptions, consider real-world impact, and reflect on questions such as, could the service be made unavailable, what are the associated risks, etc.